

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The Purpose of this assessment is to make the server and the data allocated more secure by analyzing and implementing security strategies to the current access controls of the system. This Database is extremely valuable to the business as it stored important information and it's used on a daily basis by the company employees in order to query and request data to find potential customers and so running the business of the company.

It's important to secure data inside the server as it can store sensitive data as PII information, important and competitive potential customer information, and potential important information about the company, all of which otherwise could be accessed by threat actors who could steal or change it, or even worse, access the server and disable it.

Disabling the server could have a negative major impact to the business, as it stores important data needed by the company employees in order to run the business and find potential customers, this could involve a freezing to the business running core.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
---------------	--------------	------------	----------	------

<i>Competitor</i>	Obtain sensitive information via exfiltration	1	3	3
<i>Hacker</i>	Install persistent and targeted network sniffers on organizational information systems.	2	2	4
<i>Hacktivist</i>	Alter/Delete critical information Conduct Denial of Service (DoS) attacks.	3	3	9

Approach

As the business is running on the company employees using the server to find potential new customers.

A way to obstruct this core feature of the company can represent a serious threat to the entire business.

Competitors could find a way to access the data and knowing in advance the potential new customers, this could easily lead to a failure in sales by the organization, as the competitors could contact the potential customers before the company employees.

Hackers, without proper access permissions and security controls, could easily install persistent network sniffers on organizational information systems, this could lead to them selling information to competitors and external actors, leading to a fail in sales and security consequences, as PII information could be stolen too.

Finally, the most critical threat could be an Hacktivist trying to alter or delete critical information for the company, this will lead to serious major problems to the entire infrastructure of the business and company, as there isn't a backup server, the company could lose important data permanently, even a Dos attack could be a serious threat as it would put the entire company out-of-business as the company employees could not access again to the server and the potential customers.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges and applying the principle of least privilege and the separation of duties. Encryption of data in motion using TLS instead of SSL and a PKI framework could help to avoid external actors to access the data. IP allow-listing to corporate offices to prevent random users from the internet from connecting to

the database could be implemented.

If possible, a creation of a backup server could prevent the intrusion and permanent elimination of the data from the server by malicious actors.

A defence in depth strategy must be implemented too, especially at the network layer by implementing a possible network firewall, and perimeter layer as authentication systems as cited before.

Changing the use of IPv4 to IPv6 if possible could make the entire environment more secure too.